CS 305 Project One Template

Document Revision History

Version	Date	Author	Comments
1.0	1/25/26	Hunter Miller	

Client

Instructions
Submit this completed vulnerability assessment report. Replace the bracketed text with the relevant information. In this report, identify your security vulnerability findings and recommend the next steps to remedy the issues you have found.

- Respond to the five steps outlined below and include your findings.
- Respond using your own words. You may also include images or supporting materials. If you include them, make certain to insert them in the relevant locations in the document.
- Refer to the Project One Guidelines and Rubric for more detailed instructions about each section of the template.

snhu

Developer
Hunter Miller

1. Interpreting Client Needs
Determine your client's needs and potential threats and attacks associated with the company's application and software security requirements. Consider the following questions regarding how companies protect against external threats based on the scenario information:

- What is the value of secure communications to the company?
- Are there any international transactions that the company produces?
- Are there governmental restrictions on secure communications to consider?
- What external threats might be present now and in the immediate future?
- What modernization requirements must be considered, such as the role of open-source libraries and evolving web application technologies?

Artemis Financial is a financial company that handles highly sensitive client information, which makes data security a top priority for the company. There is no specification that the company is based solely in the US, so it may be inferred that the company handles both international and domestic transactions. There are not currently any governmental restrictions on secure communications; however, it is crucial that the company protects the information of its clientele and prevents any exposure of sensitive data. External threats that may be present now or in the future are attacks on sensitive client data. It will be imperative that Artemis Financial keeps all their software up to date and use current versions to support the most secure program; this can be achieved through regulatory maintenance checks.

2. Areas of Security
Refer to the vulnerability assessment process flow diagram. Identify which areas of security apply to Artemis Financial's software application. Justify your reasoning for why each area is relevant to the software application.

The following are areas of security that apply to Artemis Financial's software application.

- Input Validation: Prevents against injection attacks
- APIs: Ensures acceptable methods for accessing data
- Cryptography: Protects user information

3. Manual Review
Continue working through the vulnerability assessment process flow diagram. Identify all vulnerabilities in the code base by manually inspecting the code.

- Outdated Version in POM.XLM file. The current version of Spring Boot is 4.0.2 (https://spring.io/projects/spring-boot)
- Vulnerability in DocData.Java. Vulnerable to SQL injections.
-

4. Static Testing

Run a dependency check on Artemis Financial's software application to identify all security vulnerabilities in the code. Record the output from the dependency-check report. Include the following items:

- The names or vulnerability codes of the known vulnerabilities
- A brief description and recommended solutions provided by the dependency-check report
- Any attribution that documents how this vulnerability has been identified or documented previously

Scan Information (show all):

- *dependency-check version*: 12.2.0
- *Report Generated On*: Sun, 1 Feb 2026 16:12:02 -0500
- *Dependencies Scanned*: 38 (20 unique)
- *Vulnerable Dependencies*: 11
- *Vulnerabilities Found*: 148
- *Vulnerabilities Suppressed*: 0
- ...

Summary

Summary of Vulnerable Dependencies (click to show all)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
bcprov-jdk15on-1.46.jar	cpe:2.3:a:bouncycastle:bouncy-castle-crypto-package:1.46:*:*:*:*:*:*:* cpe:2.3:a:bouncycastle:bouncy_castle_crypto_package:1.46:*:*:*:*:*:*:* cpe:2.3:a:bouncycastle:bouncy_castle_for_java:1.46:*:*:*:*:*:*:* cpe:2.3:a:bouncycastle:legion-of-the-bouncy-castle-java-crytography-api:1.46:*:*:*:*:*:*:* cpe:2.3:a:bouncycastle:the_bouncy_castle_crypto_package_for_java:1.46:*:*:*:*:*:*:*	pkg:maven/org.bouncycastle/bcprov-jdk15on@1.46	HIGH	4	Highest	38
hibernate-validator-6.0.18.Final.jar	cpe:2.3:a:hibernate:hibernate-validator:6.0.18:*:*:*:*:*:*:* cpe:2.3:a:redhat:hibernate_validator:6.0.18:*:*:*:*:*:*:*	pkg:maven/org.hibernate.validator/hibernate-validator@6.0.18.Final	MEDIUM	3	Highest	32
jackson-databind-2.10.2.jar	cpe:2.3:a:fasterxml:jackson-databind:2.10.2:*:*:*:*:*:*:* cpe:2.3:a:fasterxml:jackson-modules-java8:2.10.2:*:*:*:*:*:*:*	pkg:maven/com.fasterxml.jackson.core/jackson-databind@2.10.2	HIGH	6	Highest	39
log4j-api-2.12.1.jar	cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.12.1	MEDIUM	2	Highest	42
logback-core-1.2.3.jar	cpe:2.3:a:qos:logback:1.2.3:*:*:*:*:*:*:*	pkg:maven/ch.qos.logback/logback-core@1.2.3	HIGH	2	Highest	31
snakeyaml-1.25.jar	cpe:2.3:a:snakeyaml_project:snakeyaml:1.25:*:*:*:*:*:*:*	pkg:maven/org.yaml/snakeyaml@1.25	CRITICAL	8	Highest	44
spring-boot-2.2.4.RELEASE.jar	cpe:2.3:a:vmware:spring_boot:2.2.4.release:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot@2.2.4.RELEASE	CRITICAL	3	Highest	39
spring-core-5.2.3.RELEASE.jar	cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:*	pkg:maven/org.springframework/spring-core@5.2.3.RELEASE	CRITICAL*	12	Highest	36
spring-web-5.2.3.RELEASE.jar	cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:*	pkg:maven/org.springframework/spring-web@5.2.3.RELEASE	CRITICAL*	13	Highest	34
tomcat-embed-core-9.0.30.jar	cpe:2.3:a:apache:tomcat:9.0.30:*:*:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@9.0.30	CRITICAL*	47	Highest	30
tomcat-embed-websocket-9.0.30.jar	cpe:2.3:a:apache:tomcat:9.0.30:*:*:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-websocket@9.0.30	CRITICAL*	48	Highest	30

* indicates the dependency has a known exploited vulnerability

bcprov-jdk15on-1.46.jar

Description: The Bouncy Castle Crypto package is a Java implementation of cryptographic algorithms. This jar contains JCE provider and lightweight API for the Bouncy Castle Cryptography APIs for JDK 1.5 to JDK 1.7.

Solution: Update to the latest version

hibernate-validator-6.0.18.Final.jar

Description: Hibernate's Bean Validation (JSR-380) reference implementation.

Solution: Update to the latest version

jackson-databind-2.10.2.jar

Description: General data-binding functionality for Jackson: works on core streaming API

Solution: Update to the latest version

log4j-api-2.12.1.jar

Description: The Apache Log4j API

Solution: Update to the latest version

logback-core-1.2.3.jar

Description: logback-core module

Solution: Update to the latest version

snakeyaml-1.25.jar

Description: YAML 1.1 parser and emitter for Java

Solution: Update to the latest version

spring-boot-2.2.4.RELEASE.jar

Description: Spring Boot

Solution: Update to the latest version

spring-core-5.2.3.RELEASE.jar

Description: Spring Core

Solution: Update to the latest version

spring-web-5.2.3.RELEASE.jar

Description: Spring Web

Solution: Update to the latest version

tomcat-embed-core-9.0.30.jar

Description: Core Tomcat implementation

Solution: Update to the latest version

tomcat-embed-websocket-9.0.30.jar

Description: Core Tomcat implementation

Solution: Update to the latest version

5. Mitigation Plan

Interpret the results from the manual review and static testing report. Then identify the steps to mitigate the identified security vulnerabilities for Artemis Financial's software application.

To mitigate security vulnerabilities, Artemis Financial should ensure all versions of dependencies are updated to the most recent version. This will ensure that the software is using the most secure version to date. Current versions will include patches that may not be included in other versions.